

DOCKER

Modül 17.8.2

Least Privilege (En Az Yetki)

Konteynerleri Root olarak çalıştırmayı bırakın

Data Science RoadMap

Alican Kaya

github.com/AlicanKaya192

Varsayılan Olarak Root

Aksini belirtmediğiniz sürece, Dockerfile'daki komutlar ve çalışan konteynerdeki uygulama 'root' kullanıcısı ile çalışır. Saldırgan uygulamayı ele geçirirse, doğrudan root yetkisiyle host'a sıçrama şansı çok artar.

USER Talimatı ile Kullanıcı Değiştirme

Güvenli bir Dockerfile hazırlarken, önce standart bir sistem kullanıcısı (ve grubu) oluşturulmalı, dosya yetkileri ayarlanmalı ve ardından `USER` komutuyla yetkiler düşürülmelidir.

```
dockerfile

FROM node:18-alpine

# 1. Gerekli dosyaları kopyala
WORKDIR /app
COPY package.json ./
RUN npm install
COPY . .

# 2. appuser adlı yetkisiz bir kullanıcı oluştur
RUN addgroup -S appgroup && adduser -S appuser -G appgroup

# 3. app klasörünün sahipliğini ona ver
RUN chown -R appuser:appgroup /app

# 4. Bundan sonraki komutları (ve CMD'yi) appuser olarak çalıştır
USER appuser

CMD ["node", "server.js"]
```

Rootless Docker (İleri Seviye)

Docker Daemon'ın kendisini (dockerd) root yerine sıradan bir kullanıcı olarak çalıştırma yöntemidir. Kurulumu biraz zahmetli olsa da, sisteminizi Container Breakout saldırılarına karşı mutlak güvenceye alır.

[*] İPUCU

Bir konteynerin hangi kullanıcı ile çalıştığını doğrulamak için:

```
docker run my_image whoami
```

(Çıktı 'root' ise tehlikeli sulardasınız demektir)